

Anvy's Hub

Information Technology Policy

Field	Details
IT Policy:	Information Security
Policy No:	ANVYS-ISP-2026-001
Updated:	April 24, 2026
Issued By:	System Administrator
Owner:	Anvy's Hub Management

1.0 Purpose and Benefits

This policy defines the mandatory minimum information security requirements for Anvy's Hub, a centralized Human Resources, Payroll, Point-of-Sale (POS), and Event Management platform. Any personnel operating within the system must, at a minimum, achieve the security levels required by this policy.

This policy acts as the governing document for all security-related procedures within Anvy's Hub. It defines the responsibility to:

- Protect and maintain the confidentiality, integrity, and availability of employee records, financial data, and business transaction information managed within the platform;
- Manage the risk of security exposure or compromise across all system modules (Employee Management, Payroll, Attendance, POS, Inventory, and Events);
- Assure a secure and stable application environment across all operating locations (SM Ecoland Branch, NCCC Branch, DGT Branch);
- Identify and respond to events involving information asset misuse, loss, or unauthorized disclosure — particularly concerning Personally Identifiable Information (PII) such as government identification numbers;
- Promote and increase the awareness of information security among all system users.

Failure to secure the confidentiality, integrity, and availability of information assets within Anvy's Hub can result in unauthorized payroll tampering, identity theft through exposed government IDs, financial fraud through the POS module, and violations of the Data Privacy Act of 2012 (Republic Act No. 10173).

This policy benefits Anvy's Hub by defining a framework that assures appropriate measures are in place to protect sensitive data, and assures all personnel understand their roles, responsibilities, and the consequences of non-compliance.

2.0 Authority

This policy is issued under the authority of the Anvy's Hub System Administrator and the Business Owner. The System Administrator is responsible for maintaining, enforcing, and updating this policy. All users who access the system — whether through the administrative dashboard, the employee attendance kiosk, or the POS terminal — are subject to this policy.

3.0 Scope

This policy encompasses all modules and components of the Anvy's Hub platform, including:

Module	Description
Employee Management	Employee profiles, government IDs (TIN, SSS, PhilHealth, Pag-IBIG), contact information, addresses, hourly rates, and basic salary data
Attendance Tracking	Clock-in/clock-out records authenticated via 4-digit PINs (clock_pin)
Payroll Generation	Individual and bulk payroll calculation, payslip generation, deduction processing, and payment status tracking
Point-of-Sale (POS)	Sales transactions, product inventory, and daily revenue records
Inventory Management	Stock levels, low-stock alerts, and product catalog data
Event Management	Event bookings, event packages, and scheduling
Reports	Sales reports, payroll reports, inventory reports, and event reports

This policy applies to all information regardless of form or format — whether stored in the MySQL database, displayed on the React frontend, transmitted via API endpoints, or printed as physical payslip documents.

It covers all physical locations where the system is accessed, including but not limited to:

- Main Branch (123 Main St, Davao City)
- Downtown Kiosk (456 Downtown Ave, Davao City)
- Mall Pop-up (789 SM Mall, Davao City)

4.0 Information Statement

4.1 Organizational Security

Information security within Anvy's Hub requires both a risk management function and a technical security function. Given the scale of the organization, the Owner serves in both

capacities — acting as both the executive decision-maker and the system administrator. The Owner is responsible for:

- Evaluating risk-related considerations for all information assets, including employee PII, payroll records, and POS transaction data;
- Ensuring that the management of information security risks is consistent with the organization's risk tolerance;
- Maintaining overall responsibility for the security of all information within the system, including its technical infrastructure.

4.2 Functional Responsibilities

4.2.1 Owner

The Owner is the business executive who holds ultimate accountability for all information within Anvy's Hub. The Owner is responsible for:

- Evaluating and accepting residual risk on behalf of the organization;
- Supporting the consistent implementation of this information security policy;
- Approving access levels for all personnel (determining who receives Administrator privileges vs. Staff privileges);
- Determining the classification of information assets and approving data handling procedures;
- Complying with notification requirements under the Data Privacy Act of 2012 (RA 10173) in the event of a breach of private information;
- Reviewing audit logs and incident reports prepared by the Admin; and
- Communicating the requirements of this policy and the consequences of non-compliance to all personnel.

4.2.2 Admin

The Admin (`is_admin = true`) is the designated system operator responsible for the day-to-day management and technical security of Anvy's Hub. The Admin is responsible for:

- Maintaining the Laravel backend, React frontend, and MySQL database infrastructure;
- Managing user accounts, role assignments, and authentication credentials;
- Generating individual and bulk payroll, managing employee records, and processing attendance data;
- Monitoring system logs and audit trails for anomalies;
- Responding to potential security incidents, including unauthorized access attempts and data integrity issues;
- Managing database backups, system updates, and vulnerability patches;
- Configuring and maintaining geofencing and IP whitelisting controls for attendance kiosks;

- Promoting information security awareness among all system users; and
- Reporting security concerns and incidents to the Owner.

4.2.3 Staff / Employees

All staff members and employees who interact with the system are responsible for:

- Understanding the baseline information security controls necessary to protect the confidentiality, integrity, and availability of information entrusted to them;
- Protecting their personal authentication credentials (login passwords and 4-digit clock PINs) from unauthorized use or disclosure;
- Never sharing their clock_pin with other employees for the purpose of proxy attendance (buddy-punching);
- Reporting suspected information security incidents or weaknesses to the System Administrator immediately;
- Logging out of shared terminals (kiosks) after completing their session; and
- Abiding by the Acceptable Use provisions defined in Section 4.9 of this policy.

4.3 Separation of Duties

To reduce the risk of accidental or deliberate system misuse, the following separation of duties is enforced within Anvy's Hub:

Privilege	Administrator	Staff
View Employee Profiles	Full Access	Denied
View/Edit Government IDs	Full Access	Denied
Generate Individual Payroll	Allowed	Denied
Generate Bulk Payroll	Allowed	Denied
View Payroll Records & Payslips	Full Access	Own Payslip Only
Mark Payroll as Paid	Allowed	Denied
Manage Inventory	Full Access	Denied
Process POS Transactions	Allowed	Allowed
Clock In/Out (Attendance)	Via Dashboard	Via Clock PIN
Manage Events & Bookings	Full Access	Denied
Generate Reports	Full Access	Denied
Manage User Accounts	Full Access	Denied

Where technical separation of duties is not feasible, compensatory controls such as audit logging (activity trails) and management review must be implemented.

4.4 Information Risk Management

All system modules that support business functions must undergo information risk assessments. Risk assessments are required:

- Before the deployment of new system features or modules;

- Before significant changes to the operating environment (e.g., server migration, framework upgrades);
- In response to the discovery of a significant vulnerability (e.g., compromised credentials, SQL injection vectors);
- At a minimum, annually.

Risk assessment results and the decisions made based on these results must be documented by the System Administrator.

Identified Risks Specific to Anvy's Hub:

Risk	Impact	Likelihood	Mitigation
Compromised default passwords	Unauthorized admin access	High	Role-specific complex passwords enforced (resolved)
Unencrypted PII in database	Identity theft if database is leaked	Medium	Data encryption at rest via Laravel EncryptedCast
Buddy-punching via shared clock PINs	Payroll fraud (inflated hours)	High	Geofencing and IP whitelisting on attendance endpoints
Unauthorized payroll rate modification	Financial loss	Medium	Audit logging on all employee rate changes
Abandoned kiosk sessions	Privilege escalation	Medium	Session concurrency limits and auto-timeout
Brute-force login attempts	Account compromise	Medium	Rate limiting on authentication endpoints
Cross-site scripting (XSS) injection	Data theft, session hijacking	Low	Content Security Policy (CSP) headers

4.5 Information Classification and Handling

All information within Anvy's Hub must be classified according to the following tiers:

Classification	Description	Examples
CONFIDENTIAL	Highly sensitive data. Access restricted to authorized Administrators only.	TIN, SSS, PhilHealth, Pag-IBIG numbers, hourly rates, basic salary, net pay, payslip details, employee addresses
INTERNAL	Operational data. Not intended for public disclosure.	Attendance records, clock-in/out timestamps, employee names, contact numbers, work schedules, department assignments, job titles
PUBLIC	Information intentionally available to the general public.	Event packages, menu items, store locations and addresses, business operating hours

Handling Requirements:

- CONFIDENTIAL data must be encrypted at rest in the database and must never be displayed in full on shared screens or printed documents without authorization.
- INTERNAL data must be protected from unauthorized external access but may be shared among authorized system users as needed.
- PUBLIC data may be freely displayed on customer-facing interfaces but must be reviewed by the System Administrator before publication.
- All reproductions of CONFIDENTIAL information (e.g., printed payslips, exported CSV reports) must carry the same classification.
- CONFIDENTIAL data must be securely disposed of when no longer needed, including secure deletion from database backups.

4.6 IT Asset Management

All IT hardware and software assets used to access or operate Anvy's Hub must be inventoried and assigned to a responsible individual or location.

Hardware Assets:

Asset	Location	Responsible Party
Admin Workstation	NCCC Branch	System Administrator
POS Terminal	All Branch	On-duty Staff
Attendance Kiosk	NCCC Branch	System Administrator
POS Terminal	All branch	On-duty Staff
POS Terminal	All branch	On-duty Staff

Software Assets:

Component	Version	Purpose
Laravel Framework	11.x	Backend API and business logic
React (Inertia.js)	18.x	Frontend user interface
MySQL	8.x	Primary data storage
Node.js / Vite	Latest	Frontend build tooling
Bcrypt	Default	Password hashing

All software dependencies (via composer.json and package.json) must be regularly audited for known vulnerabilities using npm audit and composer audit.

4.7 Personnel Security

- All new employees must receive a brief security orientation from the System Administrator within their first week of employment, covering: proper use of their clock PIN, password confidentiality obligations, and this policy's acceptable use provisions.

- Upon account creation, employees are assigned a secure default password (Anvystaff@2026). Employees must be instructed to change this password upon first login once a password change feature is implemented.
- Administrator accounts are assigned a separate, distinct default password (Anvyadmin@2026) that must not be shared with non-administrative personnel under any circumstances.
- All 4-digit clock PINs (clock_pin) are unique per employee and must be treated as confidential authentication tokens. Sharing of clock PINs is a direct violation of this policy.

Upon an employee's separation from the organization (termination or resignation):

- Their user account must be disabled immediately via soft-delete;
- Their clock_pin must be invalidated;
- Any active sessions must be terminated; and
- All issued property (keys, access cards) must be returned before separation is finalized.

4.8 Cyber Incident Management

Anvy's Hub must maintain a documented incident response procedure to effectively respond to security incidents. The following categories of incidents are defined:

Severity	Description	Examples	Response Time
Critical	Confirmed unauthorized access to CONFIDENTIAL data or system compromise	Database breach exposing TIN/SSS numbers; unauthorized bulk payroll generation	Immediate (within 1 hour)
High	Suspected unauthorized access or significant system malfunction	Suspicious login activity; payroll inconsistencies	Within 4 hours
Medium	Policy violations or minor security events	Employee sharing clock PIN; failed login attempts exceeding threshold	Within 24 hours
Low	Informational events requiring documentation only	Minor configuration changes; routine scan findings	Within 1 week

Incident Response Procedure:

1. Detection & Reporting: Any employee who observes or suspects a security incident must report it to the System Administrator immediately.
2. Assessment: The System Administrator assesses the scope, severity, and potential impact of the incident.

3. Containment: Affected accounts are disabled, sessions are terminated, and compromised endpoints are taken offline if necessary.
4. Investigation: System logs, audit trails, and database records are examined to determine the root cause and extent of the breach.
5. Notification: If the incident involves a breach of personal information, the Business Owner must be notified immediately. If the breach falls under the Data Privacy Act of 2012, the National Privacy Commission (NPC) must be notified within 72 hours.
6. Recovery: Affected systems are restored from clean backups, compromised credentials are reset, and patched versions are deployed.
7. Post-Incident Review: A written report documenting the incident, response actions, and preventive measures is prepared and retained.

4.9 Physical and Environmental Security

All physical locations where Anvy's Hub is accessed must adhere to the following security controls:

- Kiosk Terminals: Attendance kiosks at branch locations must be positioned in areas visible to management staff. Kiosks must not be placed in unmonitored areas.
- Screen Privacy: Terminals used to access CONFIDENTIAL data must be positioned to prevent shoulder-surfing by customers or unauthorized personnel.
- Auto-Lock: All terminals must be configured to lock the screen after 5 minutes of inactivity, requiring re-authentication to resume.
- Physical Access: Server rooms or locations housing the database server (if on-premises) must be restricted to the System Administrator only.
- Terminal Disposal: Before decommissioning any terminal, all locally cached data (browser storage, saved credentials) must be securely wiped.

4.10 Account Management and Access Control

- All system access must be provided through individually assigned unique credentials. Shared accounts are strictly prohibited.
- Each user account is assigned one of two roles: Administrator (is_admin = true) with full access, or Staff (is_admin = false) with limited access as defined in Section 4.3.
- Passwords must not be written on paper, stored in unencrypted files, or saved in browsers on shared terminals.
- Clock PINs must not be shared, written on sticky notes, or communicated to other employees.

Session Management:

- Sessions must automatically terminate after 30 minutes of inactivity.
- Only one active session per user account is permitted at any time. Logging in from a new device must invalidate all previous sessions.

Rate Limiting: The login endpoint (/login) must enforce a maximum of 5 failed attempts per minute per IP address. After exceeding this threshold, the IP must be temporarily blocked for 15 minutes.

Account Deprovisioning: Accounts of separated employees must be disabled within 24 hours of their last working day.

4.11 Systems Security

4.11.1 Application Security

The Anvy's Hub application is built on the Laravel 11.x framework (PHP 8+) with a React/Inertia.js frontend. All application code must adhere to secure coding practices:

- All database queries must use Laravel's Eloquent ORM or parameterized queries to prevent SQL injection.
- All user-submitted input must be validated server-side using Laravel's validation rules before processing.
- Cross-Site Request Forgery (CSRF) tokens must be enforced on all state-changing requests.
- Content Security Policy (CSP) headers must be configured to prevent execution of unauthorized scripts.
- API routes serving sensitive operations must be protected by authentication middleware and role-based authorization checks.
- Development tools, debug modes (APP_DEBUG=true), and verbose error messages must never be enabled in production environments.

4.11.2 Database Security

- The MySQL database must enforce authentication for all connections.
- Database credentials must be stored in the .env environment file and must never be committed to version control.
- CONFIDENTIAL fields (TIN, SSS, PhilHealth, Pag-IBIG numbers) must be encrypted at rest using Laravel's EncryptedCast.
- Direct database access must be restricted to the System Administrator only.

4.11.3 Environment Separation

- Development, testing, and production environments must be logically separated.
- Production data must never be used in development or testing environments unless CONFIDENTIAL fields are masked.

- The .env file must contain environment-specific configuration and must differ between development and production.

4.12 Vulnerability Management

- All software dependencies must be scanned for known vulnerabilities before deployment (composer audit, npm audit).
- The System Administrator must subscribe to security advisories for Laravel, React, and all critical dependencies.

Vulnerability response timeframes:

Severity	Response Timeframe
Critical (actively exploited)	Within 24 hours
High	Within 1 week
Medium	Within 1 month
Low	Next scheduled maintenance window

- The Laravel framework and all npm packages must be kept at vendor-supported versions.

4.13 Operations Security

4.13.1 System Configuration

- All system configurations must follow approved standards. The Laravel .env file serves as the primary configuration source.
- APP_DEBUG must be set to false in production.
- APP_KEY must be a unique, randomly generated 32-character key and must never be reused across environments.

4.13.2 Backup and Recovery

- Database backups must be performed daily using automated scripts (e.g., mysqldump).
- Backup files must be stored in a secure, off-site location separate from the production server.
- Backup restoration must be tested monthly to verify data integrity and recovery procedures.
- Recovery Time Objective (RTO): The system must be recoverable within 4 hours of a critical failure.
- Recovery Point Objective (RPO): No more than 24 hours of data may be lost in a disaster recovery scenario.

4.13.3 Monitoring and Logging

All administrative actions must be logged with the following metadata:

- User ID of the actor
- Action performed
- Timestamp
- Affected record(s)
- Previous and new values (for modifications)
- Audit logs must be protected from tampering and retained for a minimum of 1 year.
- The System Administrator must review audit logs weekly for anomalies.

5.0 Compliance

- This policy takes effect upon publication. Compliance is expected from all personnel who access or interact with Anvy's Hub.
- Violations of this policy may result in disciplinary action, up to and including termination of employment and revocation of all system access.
- If compliance with any provision is not technically feasible, the System Administrator must document the exception, implement compensatory controls, and obtain written approval from the Business Owner.
- This policy must be reviewed and updated at least annually.

6.0 Definitions of Key Terms

Term	Definition
PII	Any information that can be used to identify an individual, including name, address, contact number, TIN, SSS, PhilHealth, and Pag-IBIG numbers
Clock PIN	A unique 4-digit numeric code assigned to each employee for authenticating attendance clock-in and clock-out actions
Bulk Payroll Generation	The automated process of calculating and generating payslips for all eligible employees simultaneously
Geofencing	A location-based security control that restricts certain system functions to users within a defined geographical area
IP Whitelisting	A security control that permits access to specific endpoints only from pre-approved network IP addresses
Encryption at Rest	Encrypting data stored in the database so it is unreadable without the application decryption key
Session Concurrency	A control limiting each user account to a single active login session at any time
RBAC	Role-Based Access Control — restricting system access based on assigned user roles
CSRF	Cross-Site Request Forgery — an attack tricking a browser into performing unauthorized actions
CSP	Content Security Policy — an HTTP header

	instructing browsers to only execute scripts from approved sources
Soft Delete	A data handling method where records are marked as deleted but retained in the database for audit purposes

7.0 Contact Information

Submit all inquiries, incident reports, and requests for policy amendments to:

System Administrator

Anvy's Hub

Davao City, Philippines

Email: admin@anvys.com

8.0 Revision History

This standard shall be subject to periodic review to ensure relevancy.

Date	Description of Change	Reviewer
April 24, 2026	Initial policy creation and publication	System Administrator
—	—	—

9.0 Related Documents

- Republic Act No. 10173 — Data Privacy Act of 2012 (Philippines)
- National Institute of Standards and Technology (NIST) — Special Publication 800-53
- OWASP Foundation — OWASP Top 10 Web Application Security Risks (2021)
- Laravel Security Documentation — Authentication, Authorization, Encryption, and CSRF Protection
- Anvy's Hub Security Enhancement Proposal — ANVYS-SEP-2026-001 (Internal Document)